Exercise Session – Chapter 2: Network Security

Objective:
To assess and reinforce students' understanding of core network security concepts, including threats, vulnerabilities, attacks, encryption, cryptographic mechanisms, and network defense strategies.

Exercise 1: Concept Classification

Classify each item as a *Threat*, *Vulnerability*, or *Attack*. Justify your answer briefly.

Scenario	Classification	Justification
A web server running an outdated version of Apache		
A hacker scanning open ports in a network		
Using default passwords on a router		
A malicious email attachment containing ransomware		
An employee leaving their workstation unlocked		

Exercise 2: Identify Weak Points

Scenario:
A small company uses FTP for file transfers, Telnet for remote access, and has a single LAN for all departments (IT, Finance, HR).

1. Identify at least **three vulnerabilities** in this setup.
2. Suggest **security improvements** for each vulnerability.
3. Explain how each improvement mitigates the related risk.

Exercise 3: Encryption Concepts

1. What is the main difference between **symmetric** and **asymmetric** encryption?
2. Why is symmetric encryption typically faster?
3. What makes asymmetric encryption more suitable for **key exchange**?
4. Why can hashing not be decrypted?
5. What is the **avalanche effect** in hashing?

Exercise 4: Digital Signature Reasoning

Scenario:
Alice wants to send a contract to Bob and prove that she is the real sender.
She uses her private key to sign the message and sends both the contract and signature to Bob.

1. How does Bob verify that the message came from Alice?

2. What cryptographic mechanism allows this verification?
3. What would happen if the message were modified after signing?

Exercise 5: Firewall Rule Interpretation

Given ACL Rules:

```
access-list 101 deny tcp any any eq 23

access-list 101 permit tcp any any eq 80

access-list 101 permit tcp any any eq 443
```

1. Which traffic is denied?
2. Which traffic is allowed?
3. What protocol uses port 23?
4. Why would blocking this port improve network security?
5. Which OSI layer does the firewall operate at?

Exercise 6: IDS vs IPS

1. What is the difference between an **Intrusion Detection System (IDS)** and an **Intrusion Prevention System (IPS)**?
2. In what scenario would an IDS be more appropriate than an IPS?
3. At which point in the network should each be deployed?

Exercise 7: Security Principles in Action

Instructions:
For each security design principle below, describe one **practical example** of its implementation in a network environment.

Principle	**Example of Implementation**
Defense in Depth	
Least Privilege	
Network Segmentation	
Regular Updates and Patching	
Secure by Default	

Exercise Session – Chapter 2: Network Security

Exercise 1:

Scenario	Classification	Justification
A web server running an outdated version of Apache	**Vulnerability**	The outdated software may contain known security flaws that can be exploited.
A hacker scanning open ports in a network	**Attack**	Port scanning is an active attempt to find exploitable services.
Using default passwords on a router	**Vulnerability**	Default credentials make the system easy to compromise.
A malicious email attachment containing ransomware	**Attack**	It is an intentional action aiming to infect and encrypt files.
An employee leaving their workstation unlocked	**Vulnerability**	It creates an opportunity for unauthorized access if exploited.

Exercise 2:

Scenario:
A company uses FTP for file transfers, Telnet for remote access, and one flat LAN for all departments.

Vulnerability	Improvement	Justification
FTP transmits data in plaintext	Replace FTP with **SFTP** or **FTPS**	Encrypts data during transfer, protecting credentials and files.
Telnet sends passwords unencrypted	Replace Telnet with **SSH**	Provides secure, encrypted remote access.
Flat network with no separation	Implement **VLANs** or **firewall segmentation**	Limits broadcast domains and prevents lateral movement in case of intrusion.

Exercise 3:

Main difference between symmetric and asymmetric encryption:

- Symmetric uses **one shared key** for both encryption and decryption.
- Asymmetric uses **two keys**: a public key for encryption and a private key for decryption.

Why symmetric is faster:

- It uses simpler mathematical operations and shorter keys, requiring less computational power.

Why asymmetric is better for key exchange:

- The public key can be safely distributed; only the private key needs to remain secret.

Why hashing cannot be decrypted:

- Hashing is a **one-way function**—it produces a fixed-length output that cannot be reversed to retrieve the original data.

Avalanche effect:

- A small change in the input (like one bit) causes a **large, unpredictable change** in the hash output.

Exercise 4:

Scenario:
Alice signs a contract with her private key and sends it to Bob.

Question	**Answer**
1. How does Bob verify that the message came from Alice?	Bob uses Alice's **public key** to verify the digital signature. If the verification succeeds, it confirms the signature was created with Alice's private key.
2. What cryptographic mechanism allows this verification?	**Asymmetric encryption**—specifically, the use of public/private key pairs in digital signatures.
3. What happens if the message was modified after signing?	Verification will **fail**, since the hash of the modified message will not match the original signature.

Exercise 5:

Question	**Answer**
1. Which traffic is denied?	TCP traffic using port **23** (Telnet).
2. Which traffic is allowed?	TCP traffic on ports **80 (HTTP)** and **443 (HTTPS)**.
3. What protocol uses port 23?	**Telnet**.
4. Why would blocking this port improve security?	Telnet sends data (including passwords) in plaintext; blocking it prevents unauthorized remote access.

5. Which OSI layer does the firewall operate at?	**Network layer (Layer 3)**, since ACLs filter based on IP and transport protocol information.

Exercise 6:

Question	**Answer**
1. Difference between IDS and IPS	**IDS (Intrusion Detection System)** monitors and alerts on suspicious traffic. **IPS (Intrusion Prevention System)** actively blocks or rejects that traffic.
2. When is IDS more appropriate?	In environments where false positives must be avoided, such as monitoring critical systems without interrupting legitimate traffic.
3. Where should each be deployed?	**IDS:** Passive monitoring (SPAN port or network tap). **IPS:** Inline between network devices, where it can inspect and block packets.

Exercise 7:

Principle	**Example of Implementation**
Defense in Depth	Combining firewall, IDS/IPS, antivirus, and access control mechanisms for layered protection.
Least Privilege	Granting users only the permissions necessary for their tasks (e.g., limited user accounts).
Network Segmentation	Using VLANs to separate departments (e.g., HR, IT, Guest).
Regular Updates and Patching	Applying OS and software updates to remove known vulnerabilities.
Secure by Default	Disabling unused ports, services, and protocols when deploying new systems.